

tests/security/ proxy_acl_security.sh — operator guide

Revision: 1 **Last modified:** 2026-07-01T00:00:00Z **Status:** Authored + parse-clean. Runs live against the running Squid HTTP forward proxy (localhost:53128); honest SKIP (§11.4.3) when the proxy or the header-echo endpoint is unreachable.

Companion (§11.4.18) to the in-source documentation block at the top of the script.

Overview

§11.4.169 / §11.4.85 **security** suite asserting the LIVE HTTP forward proxy's ACL + header-hygiene posture with captured evidence (§11.4.69). Two hard-gated anti-bluff checks:

- **S1 — ACL deny does not leak.** A request the proxy **MUST** deny — a CONNECT to a non-SSL port, blocked by the shipped Squid rule `http_access deny CONNECT !SSL_ports` — must return the expected deny code (403 Forbidden, or 407 when per-user proxy-auth is configured) and **NEVER** a 2xx/3xx success. A success code for a must-deny target is a real LEAK (§11.4.68) → FAIL.
- **S2 — header hygiene.** The hop-by-hop Proxy-Authorization credential the client sends to the proxy must **NOT** be forwarded to the upstream ORIGIN. Proven by echoing the request back from `httpbin.org/headers` (plain HTTP so Squid parses and strips hop-by-hop headers) and asserting a client SENTINEL header IS echoed (the request really reached the origin **THROUGH** the proxy) **WHILE** Proxy-Authorization is **ABSENT** (stripped — no credential leak). A Proxy-Authorization echoed at the origin is a credential LEAK → FAIL.

Honest boundary (§11.4.6)

End-to-end Authorization / Cookie headers are addressed to the origin the client chose and **ARE** forwarded by design — that is **not** a leak. This suite gates on the hop-by-hop Proxy-Authorization (which must never reach the origin) and captures X-Forwarded-For

presence as **informational** evidence only (default Squid forwarded_for on), never a hard gate. The “credential” sent in S2 is a throwaway base64 of sentinel:leak — deliberately worthless, so asserting it is stripped never logs a real secret (§11.4.10).

Prerequisites

- Committed library tests/lib/evidence.sh (sourced — _code_in, port_is_listening, ab_pass_with_evidence, ab_skip_with_reason).
- curl, awk, grep, POSIX sh, date.
- A running Squid forward proxy on HTTP_PROXY_PORT for a non-SKIP run.
- Outbound reachability to the header-echo endpoint for S2.
- Write access to qa-results/ (gitignored).

Usage examples

- Default run against localhost:53128: `bash tests/security/proxy_acl_security.sh`
- Under host-safety caps (§12.6): `GOMAXPROCS=2 nice -n 19 ionice -c 3 bash tests/security/proxy_acl_security.sh`
- Custom deny target / echo endpoint: `SEC_DENY_TARGET=https://example.com:81/ SEC_HEADER_ECHO_URL=http://httpbin.org/headers bash tests/security/proxy_acl_security.sh`

Env knobs: HTTP_PROXY_URL (default `http://localhost:53128`), HTTP_PROXY_PORT (default `53128`), SEC_DENY_TARGET (default `https://example.com:81/`), SEC_DENY_EXPECT (default `403 407`), SEC_HEADER_ECHO_URL (default `http://httpbin.org/headers`), CURL_MAX_TIME (default `15`), SEC_EVIDENCE_DIR (default `qa-results/security/proxy_acl_<ts>`).

Edge cases

- **Deny enforced (403/407)** → S1 PASS, citing `s1_acl_deny.evidence`.
- **Success code for a must-deny target** → S1 FAIL (ACL LEAK, §11.4.68).
- **Proxy port not listening / unexpected deny code** → S1 honest SKIP (`topology_unsupported`) — cannot prove a clean deny nor a leak.
- **Canary echoed AND Proxy-Authorization absent** → S2 PASS, citing `s2_header_hygiene.evidence`.
- **Proxy-Authorization echoed at the origin** → S2 FAIL (credential LEAK).
- **Origin echo not captured through the proxy** → S2 SKIP (`network_unreachable_external`) — the security property is not assertable now.

- **Aggregate:** FAIL if any check FAILs; PASS if ≥ 1 PASS and 0 FAIL; else SKIP. Exit 1 / 0 / 3.

Internal behaviour

- `#!/usr/bin/env bash`, POSIX-clean body (`sh -n + bash -n`, §11.4.67).
- S1 classifies the deny code with a success-code recogniser so a 2xx/3xx is an unambiguous leak; 403/407 is deny-enforced.
- S2 sends a non-secret sentinel canary + a throwaway Proxy-Authorization; cross-checks the origin echo (canary present $\Rightarrow$ request transited the proxy) and asserts the hop-by-hop credential was stripped.
- `trap ... EXIT INT TERM cleanup` (§11.4.14). Resources: shell + curl only, well under §12.6.

Related

- `tests/lib/evidence.sh` — sourced anti-bluff evidence library.
- `tests/dynamic/analyzers/auth_407_analyzer.sh` — the per-user-auth 407/200 oracle (complementary auth signal).
- `tests/stress/proxy_forward_stress.sh`, `tests/chaos/proxy_restart_recovery.sh` — sibling stress + chaos suites.
- Constitution §11.4.169 / §11.4.85 / §11.4.69 / §11.4.68 / §11.4.1 / §11.4.6 / §11.4.10 / §12.6.

Last verified

2026-07-01 — authored; `sh -n + bash -n` parse-clean. The ACL-deny + header- hygiene assertions run live against the running proxy under the conductor.